COOPER UNIVERSITY HEALTH CARE • INFOSEC SOC REFERENCE

The Reputation Ledger & 3-Strike Defense System

Operational Guide to Citrix NetScaler & AnyConnect VPN Authentication Triage, Strike Escalation, Safety Shields, and SOC Pardons

1. Core Philosophy: Why We Have a Strike Ledger

Pane-O-Glass evaluates every failed and successful login across **Citrix NetScaler Gateway** and **Cisco AnyConnect VPN**. Because attackers and legitimate employees connect from different networks and exhibit different behaviors, the engine separates traffic into two primary network tiers:

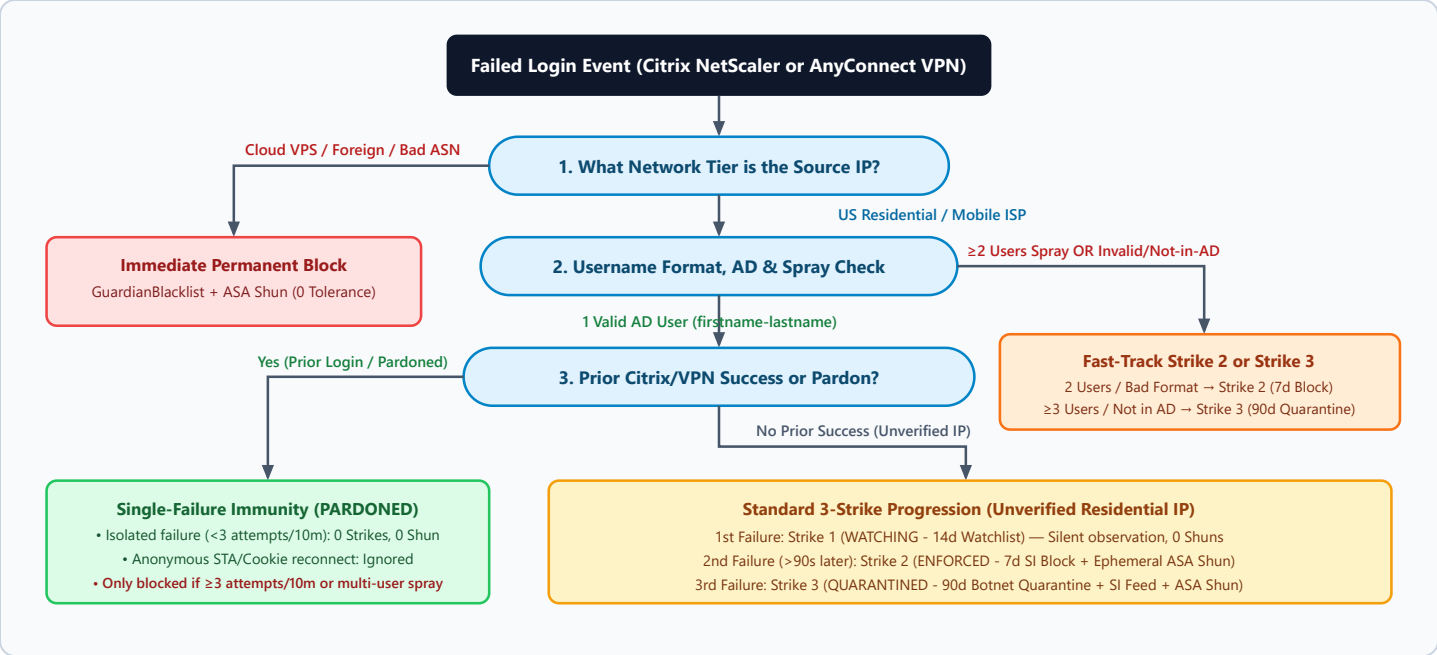
Tier A: Cloud VPS, Hosting & Blacklisted ASNs

Cloud datacenters (DigitalOcean, Linode, Vultr, OVH, Choopa, Mullvad, Tor, etc.), blacklisted ASNs, and non-US origins have **zero legitimate reason** to authenticate to Citrix or VPN. **1 failed attempt = immediate permanent block.**

Tier B: US Residential & Mobile ISPs

Consumer ISPs (Comcast, Verizon Fios, AT&T, Charter, Cox, T-Mobile) are shared by **both** remote Cooper staff and residential proxy botnets. These IPs are governed by the **3-Strike Reputation Ledger**.

2. End-to-End Decision Flowchart



3. Detailed Evaluation Rules

Rule 1: Username Format & Active Directory Verification

- **Corporate Format Requirement:** Cooper usernames strictly follow the hyphenated format `firstname-lastname` (or `name-name-name`). Attempts using non-corporate formats (e.g., `jsmith`, `john.smith`, email addresses) or honeypot names (`admin`, `root`, `backup`, `helpdesk`, `vpn`) are treated as reconnaissance probes and **skip Strike 1 directly to Strike 2 (`ENFORCED`)**.
- **Active Directory Lookup:** Every username attempted on Citrix is verified against Active Directory. If a corporate-formatted username does not exist in AD (`NOT_FOUND`), it is flagged as a dictionary probe and blocked immediately.

Rule 2: 5-Second Companion Syslog Coalescing

- When a user mistypes a password once on NetScaler or misses one Imprivata MFA push, NetScaler often logs both `AAA_POLICY_FAILED` and `AAA_LOGIN_FAILED` within 0–3 seconds.
- The triage engine coalesces companion failure events from the same IP within **5 seconds (`5000ms`)** into **1 single authentication attempt** so a single typo is never double-counted.

Rule 3: 7-Day Citrix & VPN Login History Immunity (The Guardian Safety Shield)

To prevent remote employees from being re-blocked after a single mistyped password or expired session ticket, Pane-O-Glass correlates every candidate failure IP against three historical trust sources:

1. **7-Day NetScaler Login History (`hasCitrixSuccess`):** Queries Graylog over a **7-day window** for successful NetScaler `LOGIN`, `ICASTART`, or `SSLVPN response-200` sessions from that IP and persists `hasCitrixSuccess: true` in the Reputation Ledger.
2. **AnyConnect VPN History (`hasVpnSuccess`):** Checks `VpnEvent` for prior successful AnyConnect MFA logins from that IP.
3. **Prior Pardon / Whitelist Status:** Checks if the IP has `status: "PARDONED"` or `"WHITELISTED"` in `ResidentialStrikeLedger` (and automatically ignores any failure logs that occurred *before* the pardon timestamp).

How Prior-Success Immunity Protects Employees

- **Single Failure / Isolated Retry:** If an IP has prior Citrix/VPN login success or was previously pardoned, a single failed login (or isolated retry more than 15 minutes after a prior failure) for a valid corporate user **does NOT add a strike and does NOT trigger a shun**. The IP remains `PARDONED` (0 strikes).
- **Imprivata MFA Push Timeouts:** If Imprivata RADIUS confirms the user's AD password was correct and only the smartphone Confirm ID push timed out, the IP is classified as `LEGIT_USER_ISSUE` and protected.
- **Multi-Employee Households:** Up to **2 valid active AD users** sharing a US residential ISP connection (e.g., married employees working from home) are recognized as a **Protected Household**.
- **When Protection is Revoked:** Immunity is immediately revoked if the IP attempts **multiple distinct usernames** (password spray), probes **non-existent/non-corporate accounts**, or executes a **sustained brute-force burst** (≥3 distinct failed login attempts within 10 minutes).

4. Reference Table: Strike Levels & Ledger Statuses

Ledger Status	Strikes	Firewall CLI Action	FMC SI Feed?	Retention	Trigger Criteria
`WATCHING`	**1**	None (0 Shuns)	No	14 Days	1st failure from an unverified US residential IP targeting **1 valid corporate AD user**. Silent observation.
`ENFORCED`	**2**	Dynamic Ephemeral `SHUN` (~30m hold until FMC poll)	**Yes** (Blocked)	7 Days (Rolling)	• Repeat failure on an unverified Strike 1 IP (>90s apart) • Multi-user spray (2 distinct usernames) • 1st attempt uses non-corporate format or honeypot
`QUARANTINED`	**3**	Dynamic `SHUN` + `GuardianBlacklist`	**Yes** (Blocked)	90 Days	• 3rd failure on a Strike 2 IP • Residential spray (≥3 users) or non-existent AD user probe • Unverified 10-minute auth burst (≥3 distinct attempts)
`PARDONED`	**0**	Immediate `UNSHUN` across all firewalls	No (Removed)	30 Days (Immunity)	• Automatic 4-Pillar MFA login success • Manual SOC Analyst Pardon
`WHITELISTED`	**0**	Protected (Never shunned)	No	Permanent	Explicitly whitelisted corporate or partner IP asset.

5. Dual-Enforcement Architecture (ASA CLI Shun + FMC SI Feed)

When an IP enters **Strike 2 (`ENFORCED`)** or **Strike 3 (`QUARANTINED`)**, two layers work together:

- **Layer 1 — Instant Ephemeral ASA CLI Shun:** Because Cisco FMC polls the Security Intelligence (SI) feed every ~15 minutes, Pane-O-Glass immediately pushes `shun <ip>` to the perimeter ASA firewalls with a dynamic expiration of *Next Expected FMC Poll + 20 minutes*. This closes the 15-minute FMC polling gap immediately.
- **Layer 2 — Persistent FMC Security Intelligence Feed:** The IP is published to `/api/feeds/security-intelligence`. Once FMC ingests the feed, the firewall blocks the IP natively via Access Control Policy for the full 7-day or 90-day term while the temporary CLI shun expires cleanly.

6. How Pardons Work (Automatic vs. Manual SOC Action)

A. Automatic 4-Pillar MFA Pardon

When a user logs into Citrix or VPN with MFA from a ledger IP, it is auto-pardoned if all 4 pillars pass:

1. IP only ever attempted **1 username**.
2. IP is **not** marked as a spray suspect (`isSpraySuspect: false`).
3. Authenticated username matches the failed username.
4. Verified MFA login session completed.

B. Manual SOC Analyst Pardon (360° Clearance)

Clicking **Pardon** in the Reputation Ledger or Feed Inspector performs a complete reset:

1. Sets `status = "PARDONED"` , `strikeCount = 0` , `hasCitrixSuccess = true` , and clears old `attemptedUsers` .
2. Removes the IP from `GuardianBlacklist` and marks any `NetscalerCveShun` as `REMOVED` .
3. Invalidates the FMC SI feed cache and immediately drains `unshun <ip>` across all firewalls.